POC: Exam Paper Time-Lock-מחקר ו · Case 03

לפי תבנית "מחקר ו-*POC*" של מגשימים. ה-*POC* נכתב בפייתון והורץ בפועל, והמספרים כאן הם הפלט שלו. כתוב במפורש מה אמיתי ומה מדומה.

מחקר בסיסי: רצף האירועים

- הכנה: השאלון מוצפן במפתח אקראי. המפתח מפוצל לחמישה חלקים (Shamir, סף 3).
- הפצה: כל מרכז מקבל עותק מוצפן עם עימוד ייחודי (סימן מים).
- פתיחה: בשעת הבחינה שלושה שומרי מפתח מאשרים, המפתח משוחזר, והשאלון נפתח.
- הדפסה: אם המרכז מדפיס, ההדפסה מתבצעת עכשיו (בתרחיש הדיגיטלי) או נעשתה מראש (בתרחיש הנייר).
- דליפה: אם עמוד דלף, קוראים ממנו את סימן המים ומזהים את המרכז.

מחקר בסיסי: רכיבי המערכת

- **Paper Vault**: הצפנה ופיצול מפתח.
- **Custodian App**: אישור של שומר מפתח, עם HSM או כרטיס חכם.
- **Layout Marker**: עימוד ייחודי לכל מרכז.
- **Leak Reader**: קורא סימן מים מעמוד שדלף.

מחקר בסיסי: אתגרי אבטחה

- שומרים שמשתפים פעולה: שלושה שומרים יחד יכולים לפתוח מוקדם. ההגנה: גופים שונים, ותיעוד של כל אישור.
- צילום של עמוד מודפס: כאן סימן המים צריך לעבוד.
- הקלדה מחדש ומפתח תשובות: דליפות רבות מתפשטות כטקסט מוקלד או כ"B, 2-D-1...". כאן סימן המים צריך לשרוד, וזו השאלה.

חמישה פיצ'רים מרכזיים

- פיצול מפתח 3 מתוך 5: שדה ראשוני 2^127-1.
- הצפנה: ב-POC זרם מבוסס SHA-256; בפריסה AES-256-GCM.
- סימן מים בעימוד: 12 ביטים של מזהה המרכז, מקודדים ברווחים בסוף שורות.
- קורא סימן מים: משחזר את המזהה מהעמוד.
- ציר הזמן של הקריאות: איפה, ומתי, קיים עותק קריא של השאלון.

שאלת המחקר: ה-POC

האם אפשר גם למנוע פתיחה מוקדמת של השאלון וגם לזהות מאיזה מרכז דלף, בדרכים שבהן דליפות באמת קורות?

טכנולוגיות ומגבלות: ה-POC

- פייתון טהור (`hashlib`, `secrets`).
- מגבלה חשובה: השאלון, המרכזים והדליפות מדומים. פיצול Shamir אמיתי. ההצפנה היא זרם הדגמה (בפריסה AES-GCM). "צילום" ממודל כעותק ששומר על העימוד.

תוצאות: ה-POC

מעבדה	מה מדדנו	תוצאה
פיצול	2 שומרים / 3 שומרים / 5 שומרים	2: לא נפתח · 3: נפתח · 5: נפתח. ניחוש המפתח: כ-2.7×10^18

צילום	200 דליפות בצילום, 900 מרכזים	שנים
הקלדה	אותן 200 דליפות, מוקלדות מחדש	200 מתוך 200 זוהו (100%)
הקלדה	דליפה כמפתח תשובות	0 זוהו
חלון	איפה קיים עותק קריא (ציר זמן להמחשה, לא מדידה)	נייר: בדפוס 72 שעות לפני, במשאיות ובמחסנים 36 שעות לפני · דיגיטלי: רבע שעה לפני, בשרת המרכז

מסקנות: ה-POC

- ✅ טענה 1, נעילה: הוכחה. אף שומר לבד, ואף שני שומרים, לא יכולים לפתוח.
- ❌ טענה 2, עקיבות: נכשלה במקום שחשוב. סימן המים שורד צילום, אבל דליפות מתפשטות בעיקר כטקסט מוקלד או כמפתח תשובות, ושם הוא נמחק לגמרי. סימן מים בניסוח היה שורד, אבל הוא משנה את השאלות בין מרכזים ופוגע בהוגנות.
- ❌ טענה 3, חלון: נכשלה. בחינה על נייר חייבת להיות מודפסת שעות לפני, אז הנעילה מגינה על הקובץ ולא על הנייר. הדליפה פשוט עוברת לחלון ההדפסה.

מסקנה: ❌ נופל ב-POC. הליבה הקריפטוגרפית עובדת, אבל שתיים משלוש הטענות לא מחזיקות בעולם האמיתי. מה היה מציל אותו: בחינה ממוחשבת במרכזים מבוקרים, שבה המפתח נפתח בדקה של הבחינה ואין נייר בכלל. אז הנעילה מספיקה, וסימן המים לא נחוץ.